

NationalBank Reserve - Unified Findings Register

Checkpoint 5 Deliverable | Authorized Lab Only

Analyst: Mustafa Musa Ahmed | **Year:** 2026

Consolidated Findings (C2 + C3 + C4)

ID	Source	Finding	CVSS	Severity	MITRE / OWASP	Status
NB-01	C2	DB credentials exposed via config.inc.php.bak	9.8	CRITICAL	T1552.001	Confirmed
NB-02	C3	SQL Injection (DVWA SQLi module)	9.8	CRITICAL	T1190 / A03	Confirmed
NB-03	C3	Command Injection (RCE as www-data)	9.8	CRITICAL	T1190 / A03	Confirmed
NB-04	C3	Broken Authentication (admin API no auth)	9.8	CRITICAL	T1078	Confirmed
NB-05	C3	API SQL Injection (login bypass)	9.8	CRITICAL	T1190 / API8	Confirmed
NB-06	C3	BOLA - access any user object	8.6	HIGH	API1	Confirmed

ID	Source	Finding	CVSS	Severity	MITRE / OWASP	Status
NB-07	C3	Excessive Data Exposure (pass-words + API keys)	8.2	HIGH	API3	Confirmed
NB-08	C3	Mass Assignment (self-assign admin)	8.1	HIGH	API5	Confirmed
NB-09	C3	SSRF - read local /etc/passwd	8.6	HIGH	API7	Confirmed
NB-10	C3	CSRF - password change form	8.1	HIGH	A01	Confirmed
NB-11	C3	Stored XSS	7.2	HIGH	A03	Confirmed
NB-12	C3	Reflected XSS	6.1	MEDIUM	A03	Confirmed
NB-13	C2	Directory indexing on /config/	7.5	HIGH	T1083	Confirmed
NB-14	C2	Apache 2.4.25 outdated	7.5	HIGH	T1190	Confirmed
NB-15	C2	PHPSESSID cookie without HttpOnly	5.3	MEDIUM	T1539	Confirmed
NB-16	C2	Missing security headers (CSP, HSTS, XCTO)	5.3	MEDIUM	T1185	Confirmed

ID	Source	Finding	CVSS	Severity	MITRE / OWASP	Status
NB-17	C2	Admin login page publicly exposed	3.1	LOW	T1087	Confirmed
NB-18	C3	File Upload unrestricted	8.8	HIGH	A08	Confirmed
NB-19	C4	Phishing email bypassed gateway (lab)	8.1	HIGH	T1566.002	Confirmed
NB-20	C4	Credential capture via fake portal	8.1	HIGH	T1056.003	Confirmed
NB-21	C4	Signature-only AV bypassable via XOR	7.5	HIGH	T1027	Confirmed
NB-22	C4	shikata_ga3oi encoder detected by AV	3.0	LOW	T1027.002	Observation

TOTALS: - CRITICAL: 5 (NB-01 → NB-05) - HIGH: 11 (NB-06 → NB-11, NB-13, NB-14, NB-18, NB-19, NB-20, NB-21) - MEDIUM: 4 (NB-12, NB-15, NB-16, NB-?) - see note) - LOW: 2 (NB-17, NB-22) - **Grand total: 22 findings**

Risk Matrix (Likelihood × Impact)

	Low Impact	Medium Impact	High Impact	Critical Impact
High Likelihood		NB-15, NB-16	NB-13, NB-14, NB-18	NB-01, NB-02, NB-03, NB-04, NB-05
Medium Likelihood	NB-17	NB-12, NB-22	NB-06, NB-07, NB-08, NB-09, NB-10, NB-11, NB-19, NB-20, NB-21	
Low Likelihood				

Severity Distribution

- **CRITICAL:** 5 - Immediate RCE or full authentication bypass
- **HIGH:** 11 - Data theft, privilege escalation, or account takeover
- **MEDIUM:** 4 - Defense-in-depth erosion
- **LOW:** 2 - Information disclosure / observation

Overall Risk Rating: CRITICAL

Attack Chain (Chained Exploitation)

1. **Entry:** Phishing email (NB-19) → credential capture (NB-20)
2. **Auth bypass:** API broken auth (NB-04) or API SQLi (NB-05)
3. **Lateral access:** BOLA (NB-06) + excessive data exposure (NB-07)
4. **Privilege escalation:** Mass assignment (NB-08) to admin
5. **Server compromise:** SQLi (NB-02) → command injection (NB-03) → root shell
6. **Persistence/exfil:** SSRF (NB-09) reads internal files

Full compromise achieved in **under 15 minutes** in the lab.